SECURITY ARCHITECTURE BRIEF

Trust Boundary Analysis

Literature-verified precedents and proposed capstone controls

Verification note. This revision is checked against the NotebookLM summary of six CAN/CAN-FD PQC studies. Named studies describe their own architectures; Gateway, IDS, and FL controls are labelled as proposed capstone work unless a study explicitly supports them.

1. Verified Trust Model

The external Free On Board authority is shown because ***Lightweight Cryptography and Physically Unclonable Functions for Secure In-Vehicle Communications*** stores its enrollment mapping externally. It is not silently treated as a Central Gateway database in this capstone.

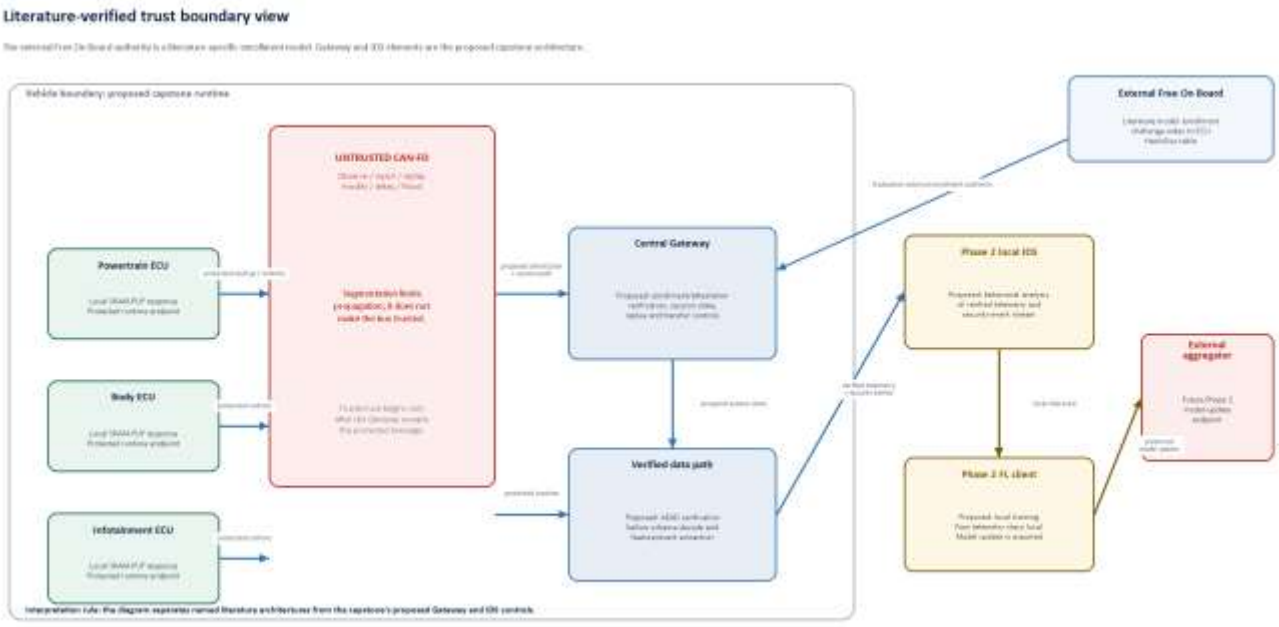


Figure 1. Literature-specific FOB enrollment model separated from the proposed Gateway and Phase 2 IDS pipeline.

How to Read This Document

Named study	A row reports only the trust storage and enforcement described by that study.
Project interpretation	A practical lesson for the capstone; it is not claimed to be an implementation detail from that study.
Proposed controls	Gateway verification, indexed recovery, feature extraction, IDS, and Flower-based FL are capstone design work and must be tested independently.

2. Literature Trust Architectures

The table deliberately uses full paper titles and descriptive boundaries. It compares what each study actually defines, not a merged protocol that none of them claims to implement.

Full paper title	Trust storage / boundary	Enforcement described	Correct capstone use
Lightweight Cryptography and Physically Unclonable Functions for Secure In-Vehicle Communications	External Free On Board stores enrollment rows mapping challenge indexes to each ECU Hash and Key. ECU locally derives a PUF response.	Free On Board challenges the ECU, verifies the Hash, and uses the matching Key to protect that ECU's symmetric session key.	If adopted, model the Free On Board as a separate enrollment authority. Do not imply the Gateway owns this table.
A Novel Hierarchical Security Solution for Controller-Area-Network-Based 3D Printing in a Post-Quantum World	Trusted parent routers store a 32-byte public-key hash and hardware ID for each authorized child node; child nodes occupy isolated subnets.	Router hashes a presented public key, authorizes only a match, and marks unverified nodes disabled before session-key release.	Useful segmentation/authorization alternative. It does not define the capstone's final Gateway database.
Securing In-Vehicle Communications Through Post-Quantum Cryptography and Network Segmentation	No dynamic node database. A pre-shared root of trust lets legitimate ECUs derive matching KEM private keys; a KeyManagement ECU is the authority.	The authority fragments a Kyber capsule across 12 CAN-FD frames under ID 046; an ECU requests resend under ID 047 and decapsulates only with the matching private key.	Supports the need to analyse key-transport fragmentation. Do not reuse its CAN IDs, key model, or frame count without validation.
Quantum-Resilient Secure Onboard Communication (QRSecOC): Integrating Post-Quantum Cryptography for Robust Automotive Network Security	No static database or public-key lookup table. Trust is a dynamic mathematical model of nodes and communication channels.	Threat conditions adjust key length or algorithm complexity; min-entropy and message weighting contribute to channel-trust assessment.	Supports configurable security trade-offs. The capstone must define measurable transition triggers before claiming adaptive protection.
PQ-CAN: A Framework for Simulating Post-Quantum Cryptography in Embedded Systems	No production trust table. Docker ECU containers communicate through a virtual CAN interface for benchmarking.	Measures congestion, timeout, key/signature-size, delivery, and latency effects across PQC candidates.	Use for simulation and performance testing only; do not cite it as runtime trust enforcement.
Lightweight, Post-Quantum Secure Cryptography Based on Ascon: Hardware Implementation in Automotive Applications	No node trust table. The focus is FPGA-accelerated Ascon authenticated encryption with associated data for CAN communication.	Ascon processing protects the CAN communication data and its identifier context under the established cryptographic key.	Supports the AEAD implementation choice. Node authorization and replay policy still require separate capstone mechanisms.

3. Proposed Capstone Trust Rules

These are project requirements from the approved workflow. They are intentionally separate from the source-comparison table so the literature is not overstated.

Enrollment authority decision	Decide whether the Central Gateway performs enrollment verification directly or communicates with an external Free On Board-like authority. Record exactly where the enrollment record, public verification data, and protected ECU material live.
Gateway acceptance rule	Accept runtime telemetry only after expected length/format, active session, freshness/replay state, and AEAD verification pass. Bind the CAN identifier and other selected visible metadata to the protected message context.
Large-object transfer rule	Treat indexed attestation transfer, selective recovery, duplicate handling, timeout, and retry limits as capstone protocol work. Test loss, duplication, reordering, malformed fragments, and recovery abuse in the simulator.
IDS isolation rule	Send only accepted/decrypted telemetry and validated protocol metadata to the Phase 2 feature pipeline. Send rejected traffic to a separate security-event stream; never parse rejected ciphertext as application telemetry.
Federated-learning scope	Keep raw vehicle telemetry local. Phase 2 model-update protection, screening, and aggregation must be designed and measured as ordinary federated learning unless the team explicitly implements a quantum mechanism.

4. Adversary Model

4.1 Adversary Model Assumptions

The proposed framework assumes an active adversary operating against a segmented CAN-FD in-vehicle network. The attacker may observe, inject, replay, spoof, delay or flood CAN-FD traffic while attempting to compromise confidentiality, integrity, availability or authenticity. The adversary model is derived from the surveyed automotive cybersecurity literature.

Boot-Time Trust Establishment:
- PUF-assisted device identity reconstruction
- ML-DSA (Dilithium) remote attestation
- Secure session establishment

Runtime Protection:
- NIST SP 800-232 Ascon-AEAD128
- Replay protection
- Gateway verification
- Gateway-hosted IDS
- Federated Learning (Phase 2)

Implementation Profile:
This project uses NIST SP 800-232 Ascon-AEAD128 with a 128-bit key, 128-bit nonce and full authentication tag (no tag truncation). Nonce uniqueness is enforced per key. Official NIST Known Answer Tests (KATs) will be used before integration.

Authenticated Insider (Masquerade) Threat:
The principal research gap addressed by this capstone is the masquerade attack. A legitimately authenticated ECU may later become compromised while retaining valid runtime credentials. Consequently, cryptographically valid messages can still be malicious. Existing PQC mechanisms authenticate identity but cannot verify runtime behaviour. The Gateway-hosted LSTM IDS therefore performs behavioural anomaly detection on authenticated runtime traffic. Automatic ECU isolation is outside the scope of Phases 1–2.

OBD-II Trust Boundary:
The OBD-II diagnostic connector is treated as an external untrusted interface terminating exclusively at the Central Gateway. No direct access to internal CAN-FD segments is permitted.

Gateway Routing Policy (Default Deny):

- Safety → Infotainment : Allow (read-only telemetry)
- Safety → Comfort : Block
- Comfort → Safety : Block
- Infotainment → Comfort : Allow selected IDs
- Infotainment → Safety : Strictly Block

Additional Technical Updates:

- Standardize all references to Ascon-AEAD128.
- Runtime spoofing protection is provided by Ascon-AEAD128 authentication tags; ML-DSA is used only during boot-time attestation.
- Replay protection authenticates counters and session metadata as Associated Data (AD).
- Black-Hole and Gray-Hole attacks are not active threats in Phases 1–2 because the architecture contains a single trusted Central Gateway and no intermediate forwarding routers. They become relevant only if intermediate routers are introduced or the Gateway trust assumption is relaxed.
- Gateway IDS performs detection, logging and alerting; automatic isolation is future work.

4.2 Trust and Technical Assumptions

2.1 Central Gateway
The Central Gateway constitutes the Trusted Computing Base (TCB) during Phases 1–2. It performs inter-segment routing, policy enforcement, runtime session management, Ascon-AEAD128 verification, IDS execution and Federated Learning coordination. The architecture contains no intermediate forwarding routers. Complete Gateway compromise is out of scope.

2.2 ECU Device Root
Each ECU reconstructs a device-specific identity using an SRAM-PUF (software emulation in Phase 1). Physical PUF security claims are deferred to hardware validation.

2.3 Runtime Communication
Runtime telemetry is accepted only after format validation, active-session validation, replay verification and Ascon-AEAD128 authentication-tag verification. A valid tag proves possession of the session key—not that the ECU remains trustworthy.

2..4 Ascon-AEAD128 Implementation Profile
- NIST SP 800-232 Ascon-AEAD128
- 128-bit key
- 128-bit nonce
- Full authentication tag (no truncation)
- Unique nonce per key
- Official NIST Known Answer Tests (KATs) before integration.

3.5 OBD-II Trust Boundary
The OBD-II connector is an external untrusted interface terminating exclusively at the Central Gateway. Diagnostic devices never receive direct access to Safety, Comfort or Infotainment CAN segments.

4.3 Adversary Capabilities

Level 1 – Passive Network Observer
Observes CAN-FD traffic, identifiers, timing and encrypted payloads. Runtime confidentiality is protected by Ascon-AEAD128.

Level 2 – Active Network Adversary
May inject, replay, spoof and flood CAN traffic or connect via OBD-II. Cannot complete ML-DSA attestation or generate valid Ascon-AEAD128 authentication tags. Replay protection authenticates counters and session

metadata as Associated Data.

Level 3 – Authenticated Insider (Masquerade) Adversary
A legitimately authenticated ECU later becomes compromised while retaining valid runtime credentials. Existing PQC authenticates identity but cannot determine whether authenticated behaviour remains trustworthy. This represents the primary research gap addressed by the project. The Gateway-hosted LSTM IDS performs behavioural anomaly detection, timing analysis, cross-sensor correlation, event logging and alert generation. Automatic ECU isolation is future work.

Level 4 – Fleet-Level Adversary
Targets Federated Learning through poisoned, replayed or malformed model updates. The implementation uses Flower FedAvg with authenticated updates, version binding, optional gradient clipping and statistical outlier rejection.

Level 5 – Quantum Adversary
Assumes a future CRQC capable of breaking classical public-key cryptography. The framework therefore uses ML-DSA for authentication and Ascon-AEAD128 for lightweight authenticated runtime protection.

Black-Hole / Gray-Hole Note
These are not active threats during Phases 1–2 because the architecture contains a single trusted Central Gateway and no intermediate forwarding routers. They become relevant only if intermediate routers are introduced or the Gateway trust assumption is relaxed.

5. Headline Contribution

Unlike existing PQC-secured CAN architectures that establish secure communication but assume authenticated ECUs remain trustworthy during runtime, the proposed framework integrates SRAM-PUF identity reconstruction, ML-DSA remote attestation, Ascon-AEAD128 protected runtime communication, segmented Gateway policy enforcement and a Gateway-hosted LSTM IDS.

The principal contribution is the detection of authenticated insider (masquerade) attacks. IDS functionality is intentionally limited to detection, logging and alert generation during Phases 1–2; automated ECU isolation is future work.